ISA/IEC 62443-3-3 / 4-2 • SL-3 TESTING CHEAT SHEET

Schneider PowerLogic ION Setup (meter configuration software) · Component type: **Software Application (SAR) - meter engineering/configuration software** · Target SL = SL 3

Where to work	**ION Setup** on a Windows host: the **Setup Assistant › Security** screens configure the METER security (Standard vs Advanced; ION9000 **.scf Security Configuration File**); ION Setup's own **site/network database** holds device connection info; installer from Schneider (signed). Auth is delegated to the meter + host OS - cross-reference the meter cheat sheets (ION7650 / ION9000 / PM8000 / PM5560).
Ports / paths	ION Setup is a client - it connects out to meters over **Modbus TCP 502**, **ION 7700**, **DNP 20000**, and (ION9000) **HTTPS 443 / SFTP 22**. The site/network config + any exported meter configs live on the host - protect them. Runs on Windows; harden the host + patch ION Setup.
Notes	SAR - Schneider PowerLogic ION Setup (meter config tool). **Thin client:** it has limited native RBAC - the security that matters is (a) the METER security it configures (assess on the meter sheet), (b) the host OS controlling who can run ION Setup, and (c) protecting the ION Setup site database / exported configs (which can hold connection info + credentials). Confirm the ION Setup version and patch level.
How to read	Each row = native step-by-step (ION Setup / host) + command-level external-tool steps, noting where control is **delegated to the meter or host**. Default read-only. Mark Pass/Fail/Partial/N/A. Write/exploit tools = isolated env + written authorization.

Project capture & evidence handling - capture the full application backup + exports

Do this BEFORE working the checklist - screenshots of the config and programming screens are not enough on their own. Capture the application's own backup and exports so nothing is missed:
1. Take the native full backup / export first (read-only, before anything): the ION Setup network / site file and per-meter configuration exports (setup templates), and the logs.
2. Export the security config: users / roles / permissions, authentication / IdP settings, audit configuration, and TLS / certificate settings - as files and screenshots.
3. Collect the logs: application, service / wrapper, audit and event logs (exports), plus running-threads / diagnostics dumps where the product provides them.
4. Capture identity & version: product edition + version / patch level, installed modules / components, and the host OS / runtime (JRE / .NET) - screenshot the About / version screen.
5. Name + protect (keep everything): `<site>_<zone>_<assetTag>_<product>_<version>_<YYYYMMDD-HHMM>_<initials>` with the native backup extension + the exports; SHA-256 hash the backup; store **only** on the encrypted evidence share; the backup usually contains secrets / credentials - **never** email it in cleartext and follow the project retention / classification policy. Do not save admin passwords in tool profiles.
6. Then analyze offsite against the product-specific checklist, the product manuals, vendor research and experience; fill in the tool and auto-generate the report - and remember the manual fields the tool can't auto-write: the **executive-summary narrative**, the **overall assurance level + justification**, and the **punch-list**.

FR 1 — Identification & Authentication Control (IAC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 1.1	Human user identification & auth	ION Setup has **no strong app-level login** of its own; authentication is enforced (a) at the **meter** - confirm Advanced security / the .scf is configured so ION Setup must supply meter credentials to change config - and (b) at the **host OS** - only authorized Windows users may run ION Setup. Verify both; record the ION-Setup-level absence as a residual. **Test:** from ION Setup, attempt a meter config change without meter credentials -> denied by the meter. **Ext. tools:** ION Setup (meter Security mode); host (who may run ION Setup); confirm meter challenges on write.	Meter enforces credentials on config; host restricts who runs ION Setup; ION-Setup residual documented.	Partial/Compensating.
SR/CR 1.2	Software process / device identification	Confirm each meter is uniquely identified in the ION Setup site/network (unique IP / Modbus/ION ID / serial) and ION Setup connects only to the intended devices. **Ext. tools:** ION Setup (site/device list); `nmap --script modbus-discover -p 502 <meter>`.	Unique meter identities in the ION Setup network; no rogue devices.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 1.3	Account management	ION Setup has no user database - manage the **host OS accounts** that may run it (least privilege) and the **meter accounts** it configures (Advanced security, named users). No shared meter credentials. **Ext. tools:** Host account review; meter user review (per the meter sheet); credential-custody record.	Host + meter accounts managed/least-privilege; ION Setup has none by design.	Compensating.
SR/CR 1.4	Identifier management	Confirm unique meter identities in the ION Setup network and unique host user IDs; no reuse. **Ext. tools:** ION Setup device list; host/AD accounts; inventory.	Unique device and host-user identifiers; no reuse.	
SR/CR 1.5	Authenticator management	Password strength is set at the meter (Advanced security) and the host (OS/AD policy) - confirm both are strong and defaults changed. Any credentials stored in the ION Setup site database must be protected (see 3.4/4.x). **Ext. tools:** Meter password policy (per the meter sheet); host/AD policy.	Strong meter + host passwords; defaults changed; stored config protected.	Delegated.
SR 1.6	Wireless access management	**N/A.** Software client with no wireless interface. **Ext. tools:** Confirm no device wireless; host WLAN governed by OS/network.	N/A - justification recorded (software).	N/A
SR/CR 1.7	Strength of password-based authentication	Confirm the password-strength policy (length/complexity/lifetime) meets SL-3. **Steps:** for this product this is assessed with the same evidence as **SR/CR 1.5** above (shared steps); confirm this requirement individually and adjudicate it separately.	Strength of password-based authentication verified individually.	
SR/CR 1.8	Public key infrastructure (PKI) certificates	For ION9000 links ION Setup uses the meter's **HTTPS/SFTP** - confirm the meter certificate is CA-signed/valid (assessed on the ION9000 sheet). For legacy meters (ION7650) there is no TLS. ION Setup itself has no PKI. **Ext. tools:** Meter cert review (ION9000); `openssl s_client -connect <meter>:443`.	Meter TLS certs valid where supported; N/A for legacy; compensating segmentation.	Delegated / N/A.
SR/CR 1.9	Strength of public key-based authentication	Confirm public-key authentication uses strong, current keys/algorithms. **Steps:** for this product this is assessed with the same evidence as **SR/CR 1.8** above (shared steps); confirm this requirement individually and adjudicate it separately.	Strength of public key-based authentication verified individually.	
SR/CR 1.10	Authenticator feedback	Confirm ION Setup masks the meter password prompt (no cleartext echo). **Ext. tools:** Visual verification.	Authenticators obscured during entry.	
SR/CR 1.11	Unsuccessful login attempts	Lockout is a meter/host concern, not ION Setup. Confirm the meter behavior (limited on legacy - PM5560 has lockout) and host/AD lockout; ION Setup adds nothing here. **Ext. tools:** Meter lockout (per meter sheet); host/AD lockout.	Lockout at meter/host where available; ION-Setup residual noted.	Delegated.
SR/CR 1.12	System use notification	No ION Setup banner; enforce the approved use notice on the host (GPO). **Ext. tools:** Host `gpresult /h gp.html`.	Use notice at the host (compensating).	Compensating.
SR 1.13	Access via untrusted networks	Confirm the ION Setup host + meters are in the trusted metering/OT zone; remote use via VPN/jump host; meter protocols not exposed to untrusted networks. **Ext. tools:** `nmap -Pn -p 502,20000,443 <meter>` from the untrusted side (expect filtered); firewall review.	Meter access from untrusted networks denied; remote via VPN.	

FR 2 — Use Control (UC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 2.1	Authorization enforcement	Authorization is enforced at the meter (Advanced-security access rights) - confirm a read-only meter account cannot change config via ION Setup - and at the host (only authorized users run ION Setup). **Test:** connect ION Setup with a read-only meter account -> config changes denied. **Ext. tools:** Meter access-rights review; host app-execution control.	Least privilege at the meter; host restricts execution; privileged actions denied.	Delegated.
SR/CR 2.2	Wireless use control	**N/A.** Software, no wireless interface. **Ext. tools:** Confirm no wireless.	N/A - justification recorded.	N/A
SR 2.3	Use control for portable/mobile devices	Control the ION Setup laptop and removable media (OS device-control); only authorized meter templates/firmware loaded; secure any optical/serial config head. **Ext. tools:** Host removable-media GPO; template/firmware provenance.	Portable/engineering media controlled.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/SAR 2.4	Mobile code	No general-purpose mobile code; confirm only the signed ION Setup runs and no untrusted add-ons/templates execute. **Ext. tools:** Installed-component review; verify installer signature.	Only signed/required components; no untrusted code.	SAR-specific.
SR/CR 2.5	Session lock	Confirm the host OS screen lock on inactivity; ION Setup re-connects to the meter (which re-challenges) after lock. **Ext. tools:** Host inactivity-lock GPO.	Host locks on inactivity; meter re-challenges.	Compensating.
SR/CR 2.6	Remote session termination	Confirm ION Setup connections to meters can be closed and the meter bounds concurrent connections so simultaneous conflicting configuration is prevented. **Ext. tools:** ION Setup connection review; meter connection limits.	Sessions terminable; concurrency bounded at the meter.	
SR/CR 2.7	Concurrent session control	Confirm concurrent sessions are bounded/limited and monitored. **Steps:** for this product this is assessed with the same evidence as **SR/CR 2.6** above (shared steps); confirm this requirement individually and adjudicate it separately.	Concurrent session control verified individually.	
SR/CR 2.8	Auditable events	ION Setup keeps limited logs; attribution comes from the meter event log (Advanced security = per-user) + the host. Capture meter config changes and forward meter/host events to the SIEM. **Ext. tools:** Meter event log (per meter sheet); host audit; SIEM.	Meter changes attributable (Advanced security); host actions logged; forwarded.	Compensating.
SR/CR 2.9	Audit storage capacity	Meter logs are finite and ION Setup logging is minimal - offload to the SIEM/SCADA for retention and alert on collection failure. **Ext. tools:** SIEM/SCADA retention + source-silent alert.	Events offloaded/retained; audit-failure alerting defined.	
SR/CR 2.10	Response to audit processing failures	Confirm a defined response to audit-processing/forwarding failures (alerting; no silent loss). **Steps:** for this product this is assessed with the same evidence as **SR/CR 2.9** above (shared steps); confirm this requirement individually and adjudicate it separately.	Response to audit processing failures verified individually.	
SR/CR 2.11	Timestamps	Confirm the host + meters are time-synced so meter-event / config-change timestamps correlate. **Ext. tools:** `w32tm /query /status`; meter time sync (per meter sheet).	Accurate, synchronized timestamps.	
SR/CR 2.12	Non-repudiation	Confirm actions are attributable to a specific user (non-repudiation). **Steps:** for this product this is assessed with the same evidence as **SR/CR 2.8** above (shared steps); confirm this requirement individually and adjudicate it separately.	Non-repudiation verified individually.	

FR 3 — System Integrity (SI)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 3.1	Communication integrity	ION Setup-to-meter comms integrity depends on the meter: ION9000 supports HTTPS/SFTP (secured); legacy meters use cleartext Modbus/ION/DNP - contain those in a segmented zone. Confirm ION Setup uses the secured path where available. **Ext. tools:** Wireshark (HTTPS/SFTP vs cleartext Modbus/ION); confirm segmentation for legacy meters.	Secured meter comms where supported (ION9000); legacy contained/segmented.	Delegated.
SR/SAR 3.2	Protection from malicious code (component)	Confirm ION Setup software integrity: install only the Schneider-**signed** ION Setup (verify the installer signature / download from Schneider); host anti-malware; restrict install to admins. **Ext. tools:** `signtool verify /pa <setup>.exe`; host AV; installed-version review.	Signed software validated; install restricted; AV active.	SAR-specific.
SR/CR 3.3	Security functionality verification	After any change re-verify (via ION Setup) that the meter security (Advanced/.scf), disabled meter services, and the host controls match the baseline; confirm ION Setup itself is patched. **Ext. tools:** ION Setup (meter settings vs baseline); host review; version check.	Meter + host security match the baseline after change; ION Setup patched.	
SR/CR 3.4	Software & information integrity	Protect the ION Setup **site/network database** and any exported meter configs (they can hold connection info/credentials): host ACLs, encrypt at rest (BitLocker), and back up under change control. Verify meter config integrity via ION Setup compare. **Ext. tools:** Host ACL on the ION Setup data folder; `certutil -hashfile <sitedb> SHA256`; ION Setup compare.	ION Setup data protected; meter config integrity verified.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 3.5	Input validation	Patch known ION Setup / meter CVEs; confirm ION Setup handles malformed meter responses without crashing. **ISOLATED:** test against a bench meter / crafted responses. **Ext. tools:** Nessus/OpenVAS on the host; Schneider SEVD cross-check; ISOLATED malformed-response test.	Known CVEs patched; malformed input handled safely.	
SR/CR 3.6	Deterministic Output	**N/A.** Device does not drive process outputs; deterministic/fail-safe output is not applicable.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 3.7	Error handling	Confirm ION Setup handles errors gracefully without leaking sensitive info (no plaintext meter credentials in logs). **Ext. tools:** ION Setup log content review.	Graceful error handling; no credential leak.	
SR/CR 3.8	Session integrity	Where the meter provides HTTPS/SFTP (ION9000) the session is integrity-protected; legacy meter sessions are cleartext - contained by segmentation. Record accordingly. **Ext. tools:** Wireshark (session inspection).	Secured meter sessions where supported; legacy contained.	Delegated.
SR/CR 3.9	Protection of audit information	Protect the meter/host/SIEM audit stores; restrict who can clear meter logs (meter rights) and the ION Setup data folder (host ACLs). **Ext. tools:** Host ACL; SIEM access review; meter log-clear permission.	Audit records protected from unauthorized read/modify/delete.	

FR 4 — Data Confidentiality (DC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 4.1	Information confidentiality	Confirm information confidentiality — sensitive data is protected in transit and at rest. **Steps:** for this product this is assessed with the same evidence as **SR/CR 3.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Information confidentiality verified individually.	
SR/CR 4.2	Information persistence	On decommission/repurpose of the host, remove the ION Setup site database, exported meter configs, credentials, and backups; confirm no plaintext meter credentials persist; encrypt the host disk. **Ext. tools:** grep exports/site DB for secrets; confirm removed; BitLocker status.	ION Setup data/credentials purged on decommission; disk encrypted.	
SR/CR 4.3	Use of cryptography	ION Setup has no native crypto of its own; confidentiality relies on the meter (HTTPS/SFTP where available) + host disk encryption + segmentation. Protect any stored credentials. **Ext. tools:** Confirm host disk encryption; meter TLS (ION9000); no plaintext creds stored.	Meter TLS + host encryption; no plaintext creds; compensating segmentation.	Delegated / Partial.

FR 5 — Restricted Data Flow (RDF)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 5.1	Network segmentation	Confirm the ION Setup host + meters sit in a segmented metering/OT zone behind a firewall; only required meter protocols cross; remote use via a jump host; no flat convergence with IT. **Ext. tools:** `nmap -p 502,20000,443,7700 <meter>` per zone; firewall rule review.	Host + meters in a segmented zone; only required flows cross.	
SR 5.2	Zone boundary protection	Confirm zone-boundary protection — only required flows cross the boundary (system SR / network device). **Steps:** for this product this is assessed with the same evidence as **SR/CR 5.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Zone boundary protection verified individually.	
SR 5.3	General-purpose person-to-person comms restrictions	**N/A.** Config software with no general-purpose person-to-person messaging. **Ext. tools:** Confirm no such services.	N/A - justification recorded.	N/A

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR 5.4	Application partitioning	Partition by criticality: keep separate ION Setup networks/site files per zone and least-privilege host access; do not co-mingle unrelated criticality. **Ext. tools:** ION Setup network/site segregation; host access review.	Networks/sites partitioned by criticality.	

FR 6 — Timely Response to Events (TRE)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 6.1	Audit log accessibility	Confirm meter event logs (via ION Setup) and host logs are readable/exportable by authorized staff and forwarded to the SIEM; passive OT IDS on the metering segment for Modbus/DNP anomalies. **Ext. tools:** ION Setup export; host logs; SIEM; passive OT IDS.	Events accessible/exportable and monitored in near-real-time.	
SR/CR 6.2	Continuous monitoring	Confirm continuous monitoring — events forwarded to and monitored by a SIEM/OT-IDS in near-real-time. **Steps:** for this product this is assessed with the same evidence as **SR/CR 6.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Continuous monitoring verified individually.	

FR 7 — Resource Availability (RA)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 7.1	Denial of service protection	ION Setup is not a runtime service; confirm the host is resourced/hardened and meter connection limits bound a flood so config access is not denied; do not co-host unrelated apps. **Ext. tools:** Host resource monitor; meter connection-limit review.	Host/connection resources bounded; config access available.	
SR/CR 7.2	Resource management	Confirm resource management — resources are bounded; no exhaustion-based loss of function. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Resource management verified individually.	
SR/CR 7.3	Control system backup	Confirm the ION Setup site database + meter templates/configs are backed up (versioned, offline) and a restore is tested (rebuild the ION Setup host + re-push a meter template to a spare). **Ext. tools:** Backup repository; restore test (host + spare meter).	Backups current and recovery validated.	
SR/CR 7.4	Control system recovery & reconstitution	Confirm recovery/reconstitution — a restore to a known-good state is tested. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.3** above (shared steps); confirm this requirement individually and adjudicate it separately.	Control system recovery & reconstitution verified individually.	
SR 7.5	Emergency Power	**N/A.** Emergency/backup power is provided at the facility/UPS level, not the device; confirm the device retains its security state across a power transfer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 7.6	Network & security configuration settings	Harden: run ION Setup on a hardened, least-privilege host; install only ION Setup (no unrelated apps); keep it patched; and use ION Setup to disable unused meter services (per the meter sheet). **Ext. tools:** Host hardening review; ION Setup version; meter service config.	Least functionality on host + meter; patched.	
SR/CR 7.7	Least functionality	Confirm least functionality — unused services/ports/protocols are disabled. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.6** above (shared steps); confirm this requirement individually and adjudicate it separately.	Least functionality verified individually.	
SR/CR 7.8	Component inventory	Inventory the ION Setup version, the host OS, and the managed meters (model/firmware) so vulnerabilities track against Schneider SEVD / CISA advisories. **Ext. tools:** ION Setup version; host inventory; Schneider SEVD feed.	Accurate version + managed-meter inventory maintained; advisories tracked.	

External Test Tools — how to use

Tool / method	Verifies	How to use — steps / example	Constraints
ION Setup	Native meter-security config & site review (all FRs)	Setup Assistant › Security (meter Standard/Advanced, .scf); site/network device list; templates; meter event log. Assess the meter itself on the meter sheet. Back up the site DB.	Read/authorized; unlock only for change tests.
Host OS controls	Who may run ION Setup + protect data (1.1, 2.1, 3.4, 4.2)	App-execution control (only authorized users), removable-media policy, ACLs + BitLocker on the ION Setup data folder / exported configs.	Windows admin review.
signtool	Signed-installer validation (SAR 3.2)	`signtool verify /pa <setup>.exe` or Properties › Digital Signatures; download from Schneider.	Read-only.
nmap	Meter/service exposure & segmentation (1.13, 5.x)	`nmap -p 502,20000,443,7700 <meter>`; `nmap --script modbus-discover -p 502`; scan per zone.	Read-only; authorized.
Wireshark	Comms integrity (3.1, 3.8)	Filter `modbus || dnp3 || http || tls`; confirm ION9000 uses HTTPS/SFTP and legacy meters stay in-zone.	Passive; SPAN/tap only.
openssl	Meter TLS (ION9000) (1.8, 4.3)	`openssl s_client -connect <meter>:443` - confirm the meter certificate where secured comms exist.	Read-only.
Nessus / OpenVAS + Schneider SEVD	CVE scan (3.5, 7.8)	Scan the ION Setup host for known CVEs; cross-check Schneider SEVD advisories for ION Setup + the meters.	ISOLATED/representative; authorization.

Controlled - Project Use · Independent Assurance Services · ISA/IEC 62443-3-3 / 4-2 · Product-specific companion to the 62443 assessment tool; confirm exact menu paths / CLI against the deployed firmware and the project hardening baseline. ISOLATED tools run only in a representative/lab environment with written authorization.